

transactions, inadequate internal controls, employee error or malfeasance, and other operational challenges inherent when processing within a multi-participant environment. To ensure these risks are mitigated, numerous technological and operational safeguards must be considered when assessing the acquiring banks' abilities to manage and control risks posed by merchants and contracted third-party payment processors.

A key mitigating factor to data integrity risk is the acquiring bank's responsibility to ensure that magnetic-strip data is not retained by merchants and third-party service providers. Many of the publicized data breaches have occurred because merchants and third-party service providers have retained customer sensitive data. Generally it is not acceptable for any participant to retain magnetic-stripe data on a post-transaction basis. Bankcard company rules prohibit-post transaction storage of full-track data (Track 1 and Track 2), CVV2/CVC2/CID/CAV, and, if applicable, the PIN block. CVV2/CVC2/CID/CAV are terms used by the various bankcard companies to refer to a unique check value that is printed on the back of the card and/or encoded in the magnetic strip. Track 1 and Track 2 data is encoded on the magnetic strip and contain information such as account number, cardholder's name, card expiration date, and service codes. Merchants and third-party service providers are allowed to store the cardholder's name, account number, and expiration date on a post-transaction basis as long as the information is encrypted, hashed, or truncated. Merchants and third-party service providers should have transaction data access protected using strong passwords and should have all data-access activity logged and available for independent review. Servers holding cardholder data should be hardened to minimize the risk of unauthorized access. Cardholder data should never be stored on a server connected to the Internet.

Historically, merchant responsibility for reporting a data breach has not been governed universally by any one entity, law, or set of guidelines other than bankcard company rules. In recent years, many states have passed legislation with various requirements for merchants reporting data breaches and various forms of financial liability.

Merchants relying on Web-based applications to conduct business should ensure that the applications are developed using IT industry secured-coding guidelines. All sensitive data transmitted via public networks must be encrypted using IT industry-standard encryption or higher. This also applies to all wireless transmissions, especially at the merchant retail level. Retail card payments containing sensitive customer information and processed using an unencrypted wireless transmission have been captured by fraudsters simply by sitting in the retailer's parking lot with a laptop computer.

Acquiring banks are ultimately responsible for any risks posed to the payment system by their sponsored merchants and third-party service providers. Management and the board of directors of all participants, including the acquiring banks, must have a clear understanding of the risk associated with acquiring activities and must understand their obligations under credit card association rules.

The credit card associations require acquiring banks to ensure that their merchants and third-party service providers comply with the Payment Card Industry Data Security Standards (PCI DSS). For third-party service providers and large merchants, PCI DSS compliance validation must be performed annually by a Qualified Security Assessor that has been approved by the PCI Security Standards Council. Smaller merchants must validate compliance annually through completion of a self-assessment questionnaire. It is not uncommon within the industry for a large number of merchants, and even some third-party service providers, to be in noncompliance with PCI DSS, potentially exposing their acquiring bank to reputation risk and financial loss from fraud, lawsuits, and fines. Additionally, issuing banks that use third-party service providers for transaction

processing are required by the card associations to ensure that their providers are in compliance with PCI DSS.

There are six categories of PCI compliance security standards. ^[53]

Build and Maintain a Secure Network

Requirement 1: Install and maintain a firewall configuration to protect cardholder data.

Requirement 2: Do not use vendor-supplied defaults for system passwords and other security parameters.

Protect Cardholder Data

Requirement 3: Protect stored cardholder data.

Requirement 4: Encrypt transmission of cardholder data across open, public networks.

Maintain a Vulnerability Management Program

Requirement 5: Use and update regularly anti-virus software.

Requirement 6: Develop and maintain secure systems and applications.

Implement Strong Access Control Measures

Requirement 7: Restrict access to cardholder data by business need-to-know.

Requirement 8: Assign a unique ID to each person with computer access.

Requirement 9: Restrict physical access to cardholder data.

Regularly Monitor and Test Networks

Requirement 10: Track and monitor all access to network resources and cardholder data.

Requirement 11: Test security systems and processes regularly.

Maintain an Information Security Policy

Requirement 12: Maintain a policy that addresses information security.

In addition to protecting cardholder information, the credit card payment process requires acquiring banks to maintain strong credit practices over their commercial customers (merchants). The credit risk incurred by acquiring banks is similar to that of ACH ODFIs in that the acquiring bank bears the financial obligation if the merchant fails to pay.

As with any line of credit, acquiring banks are responsible for ensuring credit screening of current and prospective merchants. The acquisition of new merchants is called "merchant boarding" and may be done by the acquiring bank or, more frequently, by a third party such as an ISO. The acquiring bank is responsible for due diligence of new merchants regardless of whether the bank or a third party performs the merchant boarding. The screening process should include physical inspection of premises; a credit history review; background check; and a review of business plans and operations, including projected sales volumes, chargeback activity, and type of sales (card-present or card-not-present). For online merchants, the screening process should include a

review of Web site content and functionality. Additionally, phone, mail and Web-based merchants should be monitored closely to ensure no illegal or high-risk business activity is being conducted. Of particular concern are Web sites that present higher levels of repudiation rates which could result in higher levels of credit losses.

The main source of credit risk to acquiring banks are chargebacks resulting from cardholder disputes that merchants cannot honor. When the merchant is unable to pay its chargebacks due to bankruptcy or fraud, the acquiring bank must cover the chargeback and pay the issuing bank. Acquiring banks should manage carefully the merchant portfolio and employ appropriate underwriting, chargeback processing, and fraud monitoring.

The acquiring bank is also ultimately responsible for credit and fraud risks presented by merchant accounts acquired through ISOs or MSPs. The ISO or MSP cannot be a member of a credit card association but can represent an acquiring bank in a merchant relationship. Acquiring banks must register their ISOs or MSPs with the credit card associations, and a written merchant agreement must be in place outlining the relationship, roles, responsibilities, and liability of each of the parties - ISO or MSP, merchant, and merchant acquirer.

Acquiring banks have a number of options to monitor and control credit risks in order to minimize fraud losses at the merchant level. Acquiring banks should have reports providing information such as: average sale-ticket size for the business being conducted, chargeback level and frequency, inactive merchants, percentage of manually keyed transactions to total transactions, same dollar amounts in submitted batch, large number of even dollar-amount transactions, increasing percentage of declined or referred authorizations to total sales, and continuous or frequent zero balance in DDA accounts. These reports may also be useful for identifying potential money laundering red flags.

If an acquiring bank has concerns regarding a merchant, it has the ability to delay funding, install a front-end fraud monitoring system, acquire bank statements and credit reports, and visit the merchant's place of business. Acquiring banks can also require a reserve balance be held, generally as a percentage of credit card receipts, and it can require the merchant to purchase chargeback insurance.

Examiners should assess the actions the acquiring bank has taken to ensure third-party service providers, ISOs or MSPs, and merchants are protecting the bank's interest.

EFT/POS and Credit Card Networks

Financial institutions should have accurate audit trails for all transactions at each network switch point. The audit trails should identify the originating terminal and destination. To ensure accurate transaction posting, the financial institutions should have adequate procedures in place to control transaction activity if the EFT/POS network becomes inoperable. Also, financial institutions should document and monitor procedures for balancing and settling transactions to ensure that they adhere to interchange policies. Each participant in the switch should receive adequate transaction journals and exception reports necessary to facilitate final settlement for the institution.

A financial institution should establish stand-in processing arrangements with peer financial institutions as part of its disaster recovery and business continuity plans to ensure availability of the service. Additionally, it should have adequate oversight and

contract provisions for all outsourced services to ensure continuity of expected service levels. Agreements between switch or network participants should delineate each party's liabilities and responsibilities. The agreements should detail basic control items concerning normal and contingency processing and assign responsibility for corrective action. Grievance procedures and arbitration policies are also an important part of participant agreements.

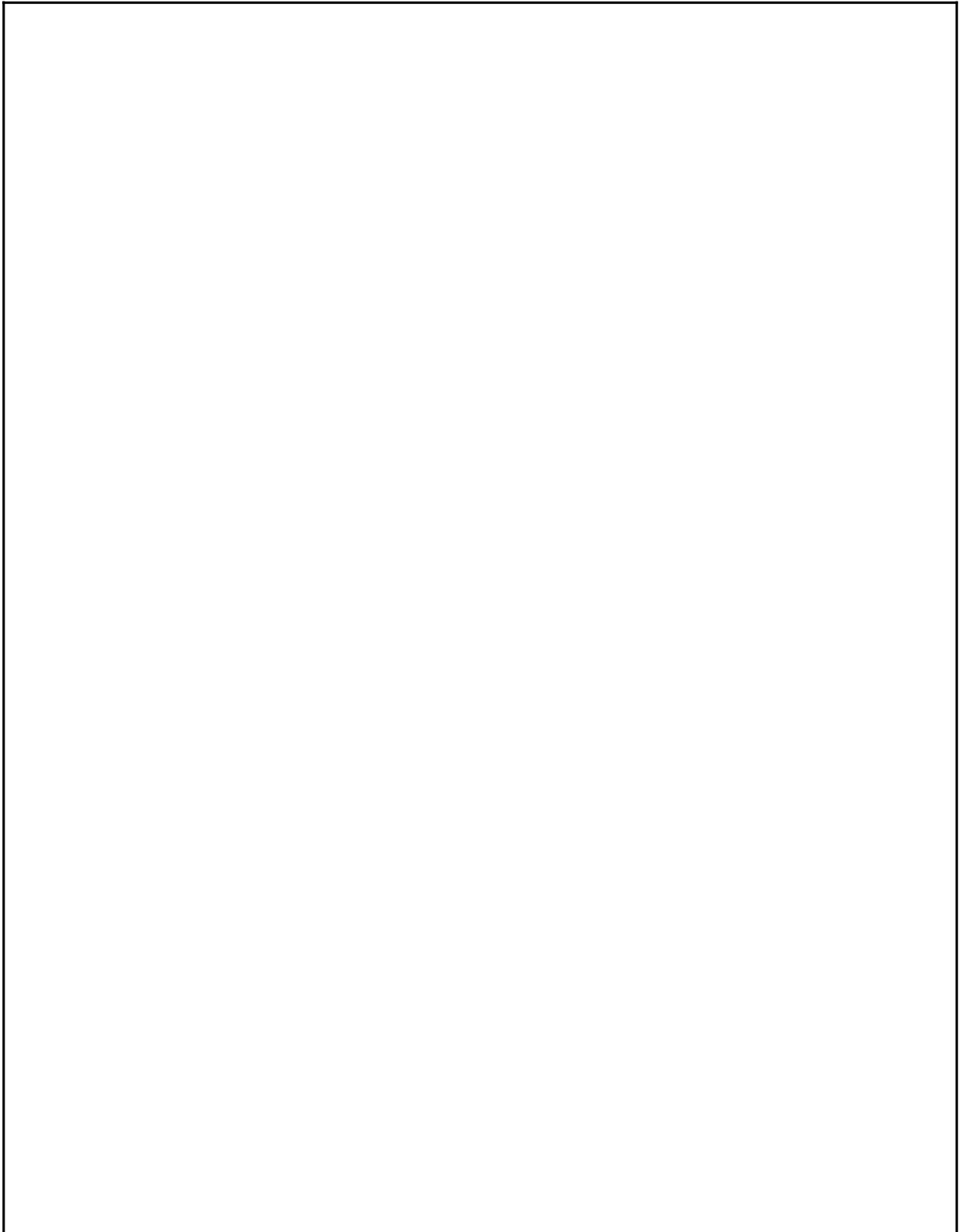
Internet and Telephone-Initiated ACH

Financial institutions originating ACH debit entries through the Internet should ensure they are in compliance with NACHA requirements. NACHA rules establish a WEB standard entry class (SEC) code for Internet-initiated ACH debit entries to which a number of requirements apply. The rules apply to originators and also affect the ODFI and its service providers. Under these rules, financial institutions must use the WEB SEC code to identify all ACH debit entries to consumer accounts that a receiver authorizes through the Internet. This code applies to both recurring and single entry ACH debits. In addition, an ODFI that transmits WEB entries must warrant that its originators have met certain NACHA standards.

Financial institutions offering TEL origination services on behalf of their customers are exposed to substantial risk from merchants that may be engaged in fraudulent or deceptive business practices. Therefore, these institutions should adopt applicable NACHA risk management practices.

Endnotes

- | | |
|------|---|
| [1] | This booklet uses the terms "institution" and "financial institution" to describe an insured bank, savings association, and credit union, as well as TSPs providing services to a financial institution. |
| [2] | This booklet references specific services and brand names including those trademarked by their respective companies. These references are intended solely to provide a retail payment systems overview and should not be construed as an FFIEC endorsement of any product or service noted herein. |
| [3] | www.ffiec.gov/exam/check21/ . |
| [4] | See "Nonbanks in the Payments System," March 6, 2003, and "A Guide to the ATM and Debit Card Industry," April 7, 2003, describing payment flows and clearing and settlement arrangements at: www.kansascityfed.org/home/subwebnav.cfm?level=3&theID=10724&SubWeb=10658#2003 . |
| [5] | NACHA is the body that establishes the rules and procedures governing the exchange of automated clearinghouse payments. |
| [6] | This booklet addresses the risks and controls associated with the bill payment transaction. See the IT Handbook E-Banking Booklet for the risks and controls associated with the front-end bill payment application used to initiate bill payments. |
| [7] | Interoperability refers to the ability of diverse retail payment systems to exchange data with a minimal loss of integrity. Many retail payment systems lack consistent protocols defining the data and the data fields in each system. Consequently, data cannot be readily moved from one system to another without manipulation. |
| [8] | For further information, see the American National Standards Web site at www.ansi.org/ . |
| [9] | Truncation is the process of removing a paper check from its processing flow. In truncation, both sides of the paper check are scanned to produce digital images. If a paper document is needed, these images are inserted into specifically formatted documents containing a photo-reduced copy of the original checks called a "substitute check." |
| [10] | The term "bank" includes any depository institution as defined in 12 U.S.C. 461 (b) (1)(A). |
| [11] | See www.ffiec.gov/pdf/pr011409_rdc_guidance.pdf for FFIEC Guidance on Risk Management of Remote Deposit Capture. |
| [12] | It is important to note that check conversion requires appropriate disclosures to the check writer and is not available for all checks. |



[13]	A remotely created check (sometimes called a "demand draft") is a check, often created by a payee or its service provider, drawn on a customer's bank account. The check often is authorized by the customer remotely, by telephone or on-line and therefore does not bear the customer's handwritten signature.
[14]	A demand draft created by the paying bank is not an RCC. See definition of RCC in Regulation CC.
[15]	The "midnight deadline" for the return of a check is midnight on the next banking day following the banking day on which the check is presented.
[16]	See www.frb services.org/files/regulations/pdf/operating_circular_3.pdf for Operating Circular No. 3: Collection of Cash Items and Returned Checks, effective July 15, 2008.
[17]	See www.ffiec.gov/pdf/pr011409_rdc_guidance.pdf for FFIEC Guidance on Risk Management of Remote Deposit Capture.
[18]	See www.ffiec.gov/bsa_aml_infobase/default.htm .
[19]	See the IT Handbook Wholesale Payment Systems Booklet for a discussion of Fedwire®.
[20]	See www.frb services.org/nationalsettlement/index.html .
[21]	Check authorization is typically performed by a third-party service provider.
[22]	The original or a qualifying substitute check is needed for presentment unless agreed to otherwise.
[23]	See www.nacha.org/ for further information on NACHA.
[24]	EPN is a subsidiary of The Clearing House (formerly known as the New York Clearing House Association).
[25]	See www.frb services.org/files/regulations/pdf/operating_circular_4.pdf for Federal Reserve System Operating Circular No. 4 on "Automated Clearing House Items."
[26]	NACHA typically uses the acronym TPSP to designate third-party service providers. Generally, TPSPs are not the same as technology service providers (TSPs), the term the FFIEC uses to denote third-party entities that provide technology services to financial institutions. It is possible that a particular TPSP may also be a TSP, but for the purposes of this booklet, no such connection is made.
[27]	See NACHA International Transactions Executive Summary: http://www.nacha.org/IAT_Industry_Information/docs/IAT%20Executive%20Summary%207%203108.pdf

-
- | | |
|------|--|
| [28] | The ODFI reporting requirements also requires ODFI to provide NACHA with information pertaining to each originator or 3rd party sender return rates which exceed a defined threshold. |
| [29] | More information about these rule changes and other developments, including proposed rules changes and pilot projects, may be found at the NACHA Web site: www.nacha.org . |
| [30] | "Merchant acquirer" is a broad term used to describe a number of industry participants including third-party service providers, independent sales organizations (ISOs), and other agents. The operating regulations of the major payment card networks require these nonbank entities to be sponsored by a member financial institution (acquiring bank) and to register with the payment network. |
| [31] | For purposes of this booklet, the bankcard systems, MasterCard and Visa,, are referenced interchangeably as companies and associations. |
| [32] | Some private label (store) credit card retailers actively manage card issuance and credit relationships through affiliated financial institutions. |
| [33] | Non-financial institution processors must be sponsored by financial institutions to process merchant transactions. |
| [34] | Each business day, the association's settlement financial institution receives information from the association about issuer and acquirer positions, sending Fedwire® 1031 draw-down messages to all of its issuers with instructions to fund their settlement accounts for those amounts. The association's settlement financial institution debits issuer accounts for those amounts and credits the appropriate acquiring financial institution accounts. If an issuer does not fund its account on time, the association will intercede, cover the short position, and assess a penalty fee on the issuer. |
| [35] | NACHA Rules Interpretation: Proper Use of SEC Codes and Aggregation of Transactions, Issued November 9, 2007, effective: August 4, 2008. This interpretation provides that transactions may not be aggregated unless specific circumstances exist; specifically, they must be aggregated under the WEB or PPD codes if the transactions are accumulated in an account for more than 14 days. |
| [36] | FFIEC Guidance "Authentication in an Internet Banking Environment," October 2005 www.ffiec.gov/press/pr101205.htm |
| [37] | See http://irda.affiniscap.com/associations/2494/files/Publications/FM_Exec_Summary.pdf |
| [38] | See the IT Handbook Outsourcing Technology Services Booklet. |
| [39] | For more details, see www.federalreserve.gov/paymentsystems/psr/relpol.htm . |
-

[40]	See the IT Handbook Wholesale Payment Systems Booklet for additional information on National Settlement Service and PSR policy.
[41]	See the IT Handbook Management Booklet
[42]	Insured depository institutions are subject to Regulation F (Limitations on Interbank Liabilities, 12 CFR Part 206) which requires institutions to monitor and limit their exposures to correspondents.
[43]	See the IT Handbook Audit Booklet.
[44]	More information on PCI Data Security Standards may be found at the website: www.pcisecuritystandards.org .
[45]	FFIEC Guidance "Authentication in an Internet Banking Environment," October 2005 & "Authentication in an Internet Banking Environment - Supplement" June 2011.
[46]	See the IT Handbook Business Continuity Planning Booklet.
[47]	See the IT Handbook Outsourcing Technology Services Booklet.
[48]	See the IT Handbook Outsourcing Technology Services Booklet.
[49]	The ACH operator usually requires an authorization from the ODFI before processing a file. Failure to receive ODFI authorization will result in the ACH operator deleting the file, giving the ODFI control over its exposure from files originated or subsequently changed by a TSP.
[50]	Automated Clearing House Rules: Article 2.1.1, Article 5.2, and Article 5.3.
[51]	Some industry publications include service providers, ISOs, and other agents in their definition of a merchant acquirer. Regardless of the term used, all participants require sponsorship by a member financial institution also known as the acquiring bank.
[52]	Source: Nonbanks in the Payments System, 2003, page 24, Federal Reserve Bank of Kansas City.
[53]	PCI Security Standards Web site: www.pcisecuritystandards.org .

Appendix A: Examination Procedures

EXAMINATION OBJECTIVE: Examiners should use the following Tier I and Tier II Retail Payment Systems examination procedures to evaluate the policies and procedures, business processes, personnel, and internal control systems of financial institutions and technology service providers. Retail payment system services include checks and share draft item processing, bankcards, payment cards, ACH, EFT/POS networks, electronic bill payment, person-to-person (P2P) and account-to-account (A2A) payment systems, and many other products and services resulting from emerging advances in technology. The examination scope should be based upon the risk profile of the financial institution or the technology service provider. The risk profile is determined through an assessment of the entity's risk environment and quality of risk management practices. This assessment should consider the formal policies and procedures established to provide these services, as well as the effectiveness of the financial institution's underlying internal control environment, including information security, business continuity, disaster recovery, and vendor management programs.

Retail payment services expose financial institutions to numerous risks, including legal, compliance, strategic, operational, credit and liquidity. Depending on the complexity of retail payment system activity, the scope of the examination may require an integrated team approach that includes the knowledge, skills, and expertise of, IT, credit, and compliance specialists.

The examination procedures may be part of either an IT or safety and soundness examination. Examiners can use the procedures in their entirety or in a modular fashion to focus on particular retail payment system products, services, or business lines. Depending on the size, complexity and risk profile of the financial institution or technology service provider, not all of the procedures may be necessary to develop overall conclusions. The examination of retail payment services may also support the institution's BSA/AML examination, which requires an evaluation of related risks in retail payment services.

The primary objectives of the Tier I procedures are to evaluate the effectiveness of the internal controls and risk management processes implemented by the financial institution or the technology service provider. Examiners should use the Tier II procedures to expand the scope of the examination further if the risk profile or organization's complexity requires additional information to establish comprehensive and accurate examination conclusions.

TIER I OBJECTIVES AND PROCEDURES

Objective 1: Assess the level of risk in retail payment systems function.

1. Determine the types of retail payment products and services offered. Consider the following: